ИТОГОВЫЙ ОТЧЕТ ПО БЕЗОПАСНОСТИ ИНФРАСТРУКТУРЫ ACME

Дата: 12 июня 2026 г.
Автор: АБ

СОДЕРЖАНИЕ

1. Резюме
2. Результаты сканирования уязвимостей (OpenVAS)
3. Аудит Active Directory (Ping Castle)
4. Анализ событий безопасности (Wazuh SIEM)
5. Критические риски и рекомендации
6. Приложения

РЕЗЮМЕ

В ходе комплексной проверки безопасности инфраструктуры выявлено критическое количество уязвимостей требующих немедленного устранения:

- 1 критическая уязвимость (CVSS 10.0) - возможность удаленного выполнения кода
- 3 высокоуровневые уязвимости (CVSS 7.5)
- 13 уязвимостей среднего уровня
- 20+ рисков конфигурации Active Directory
- Активные атаки brute-force зафиксированы в SIEM

Общий уровень риска: КРИТИЧЕСКИЙ

РЕЗУЛЬТАТЫ СКАНИРОВАНИЯ УЯЗВИМОСТЕЙ (OpenVAS)

Целевая система

- Хост: 10.0.20.67 (ms3.acme.skb)
- Дата сканирования: 17 мая 2022 г.
- Всего найдено: 438 результатов

Распределение по критичности

Уровень	Количество	Процент
Critical	1	0.2%
High	3	0.7%
Medium	13	3.0%
Low	3	0.7%

КРИТИЧЕСКИЕ УЯЗВИМОСТИ

1. Drupal Coder RCE (CVSS 10.0)

CVE: SA-CONTRIB-2016-039
Описание: Уязвимость удаленного выполнения кода в модуле Coder для Drupal
Вектор атаки: Сетевой, без аутентификации
Влияние: Полный контроль над системой
Рекомендации:

- Немедленно обновить Drupal и все модули до последних версий
- Проверить систему на наличие компрометации
- Ограничить доступ к административным интерфейсам

ВЫСОКОУРОВНЕВЫЕ УЯЗВИМОСТИ

2. SQL Injection в Drupal Core (CVSS 7.5)

CVE: CVE-2014-3704 (SA-CORE-2014-005)
Описание: SQL-инъекция в ядре Drupal 7.x до версии 7.32
Влияние:

- Выполнение произвольного SQL-кода
- Компрометация базы данных
- Повышение привилегий

Рекомендации:

- Обновить Drupal до версии 7.32 или выше
- Провести аудит базы данных на предмет несанкционированных изменений

3. Опасные HTTP методы (CVSS 7.5)

Описание: На веб-сервере включены методы PUT и DELETE
Влияние:

- Возможность загрузки вредоносных файлов
- Удаление критических файлов системы

Рекомендации:

- Отключить методы PUT и DELETE в конфигурации веб-сервера
- Настроить правила WAF для блокировки опасных методов

4. Уязвимые шифры SSL/TLS (CVSS 7.5)

CVE: CVE-2016-2183 (SWEET32)
Описание: Сервер поддерживает уязвимые наборы шифров с 3DES
Влияние: Возможность перехвата и расшифровки трафика
Рекомендации:

- Отключить TLSv1.0 и TLSv1.1
- Отключить шифры с 3DES и RC4
- Включить только TLSv1.2+ с современными шифрами (AES-GCM)

УЯЗВИМОСТИ СРЕДНЕГО УРОВНЯ

5. XSS в jQuery (CVSS 6.1)

CVE: CVE-2012-6708, CVE-2011-4969
Версия: 1.6.2 (требуется 1.9.0+)
Расположение:

- /phpmyadmin/js/jquery/jquery-1.6.2.js
- /phpmyadmin/setup/../js/jquery/jquery-1.6.2.js

6. Слабые алгоритмы SSH (CVSS 5.3)

Проблемы:

- Weak Host Key: ssh-dss (DSA)
- Weak KEX: diffie-hellman-group1-sha1 (1024-bit)
- Weak Encryption: 3des-cbc, arcfour, aes*-cbc
- Weak MAC: hmac-md5, hmac-sha1-96

7. Устаревшие протоколы TLS (CVSS 4.3)

Протоколы: TLSv1.0, TLSv1.1
Риски:

- BEAST (CVE-2011-3389)
- FREAK (CVE-2015-0204)

8. Открытые установщики веб-приложений (CVSS 5.0)

URL: http://ms3.acme.skb/phpmyadmin/setup/index.php
Риск: Возможность переустановки и конфигурирования приложений

9. Раскрытие чувствительных файлов (CVSS 5.0)

Найдено:

- /drupal/web.config (конфигурация IIS/ASP.NET)
- FTP без шифрования (порт 21)
- Передача паролей в открытом виде

! Примечание:

Сканирование OpenVAS было выполнено только для хоста ms3.acme.skb (10.0.20.67), поскольку это учебная машина Metasploitable, специально подготовленная для демонстрации уязвимостей. Другие хосты не были включены в сканирование из-за сетевых ограничений учебного стенда и специфики учебного задания, где основной акцент был сделан на мониторинге через Wazuh, который, согласно условиям задания, охватывает все хосты инфраструктуры.

АУДИТ ACTIVE DIRECTORY (Ping Castle)

Общая информация

- Домен: acme.skb
- Контроллер домена: DC01 (Windows Server 2019)
- Дата последнего бэкапа AD: 290 дней назад
- Общий балл риска: 70/100

КРИТИЧЕСКИЕ ПРОБЛЕМЫ

1. Привилегированные учетные записи (20 баллов)

Проблема: Административные учетные записи не имеют флага "Account is sensitive and cannot be delegated"
Количество: 5 учетных записей
Риск: Возможность атак с делегированием (Kerberos delegation attacks)

2. Устаревшие протоколы аутентификации (15 баллов)

Проблема: LAN Manager Authentication Level позволяет NTLMv1 и LM
Риск:

- Перехват и расшифровка хэшей
- Pass-the-Hash атаки

Рекомендации:

- Установить уровень "Send NTLMv2 response only"
- Включить Extended Protection for Authentication

3. Отсутствие резервного копирования (15 баллов)

Проблема: Последний бэкап AD выполнен 290 дней назад
Риск: Невозможность восстановления при атаке ransomware или сбое
Рекомендации:

- Настроить ежедневное резервное копирование AD
- Проверить целостность существующих бэкапов
- Хранить бэкапы изолированно от основной сети

4. Пароли сервисных учетных записей (15 баллов)

Проблема: 3 учетные записи в Domain Admins с неистекающими паролями
Риск: Постоянный доступ при компрометации
Рекомендации:

- Включить истечение паролей для всех учетных записей
- Использовать Managed Service Accounts (gMSA)
- Внедрить LAPS для локальных администраторов

5. Отсутствие LAPS (15 баллов)

Проблема: LAPS не установлен
Риск: Одинаковые локальные пароли на всех компьютерах
Рекомендации:

- Установить и настроить LAPS
- Настроить ротацию паролей каждые 30 дней

6. Политика паролей (10 баллов)

Проблема: Минимальная длина пароля менее 8 символов
Текущие настройки:

- MinimumPasswordLength: 7
- MaximumPasswordAge: 365 дней
- PasswordComplexity: включена
- PasswordHistorySize: 24

Рекомендации:

- Увеличить минимальную длину до 14+ символов
- Включить историю последних 24 паролей
- Рассмотреть внедрение Azure AD Password Protection

7. Аудит и мониторинг (10 баллов)

Проблема: Политика аудита на контроллерах домена не собирает ключевые события
Отсутствует аудит:

- Изменения в AD
- Доступ к чувствительным объектам
- Изменения политик безопасности

Рекомендации:

- Включить Advanced Audit Policy Configuration
- Настроить сбор событий 4624, 4625, 4672, 4720, 4732
- Интегрировать с SIEM (Wazuh)

8. Защищенные пользователи (10 баллов)

Проблема: 5 администраторов не входят в группу Protected Users
Риск: Уязвимость к атакам Pass-the-Hash и Kerberos
Рекомендации:

- Добавить всех привилегированных пользователей в Protected Users
- Включить Kerberos Armoring

9. Удаленный доступ к Spooler (10 баллов)

Проблема: Служба диспетчера печати доступна удаленно на 1 DC
CVE: PrintNightmare (CVE-2021-34527)
Риск: RCE с привилегиями SYSTEM

Рекомендации:

- Отключить службу Print Spooler на всех DC
- Применить патчи безопасности

СТАТИСТИКА УЧЕТНЫХ ЗАПИСЕЙ

Пользователи

- Всего: 7
- Активных: 6
- С неистекающим паролем: 5 (83%)
- Без поддержки AES: 1

Привилегированные группы

Группа	Членов	С неистекающим паролем
Administrators	5	5 (100%)
Domain Administrators	3	3 (100%)
Enterprise Administrators	1	1 (100%)
Schema Administrators	1	1 (100%)

Компьютеры

- Всего: 4
- С TrustedToAuthenticateForDelegation: 1

АНАЛИЗ СОБЫТИЙ БЕЗОПАСНОСТИ (Wazuh SIEM)

Общая статистика

Период анализа: 12 июня 2021 - 12 июня 2022
Агент с наибольшим числом алертов уровня 15: lin-target (10.0.20.63)

ТОП событий по правилам

Rule ID	Описание	Уровень	Количество
40703	Systemd service failed	5	1,325
60106	Windows logon success	3	1,078
60137	Windows User Logoff	3	635
2904	Dpkg half configured	7	437
5104	Interface in promiscuous mode	8	428
200010	Brute-force attack detected	5	48
60122	Logon failure - bad password	5	41

Анализ нормальных метрик и baseline по инцидентам за 2022 год

Общие показатели за год

Метрика	Значение	Описание

Общее количество событий	6 842	Все события безопасности за год
Среднее количество событий в день	~18.7	Нормальный baseline дневной активности
Events Per Second (EPS)	0.00022	Средняя нагрузка на SIEM
Пиковый EPS	0.15	Максимальная нагрузка (во время сканирований OpenVAS)
Критичные инциденты (Level ≥ 10)	72	1.05% от общего числа событий
Среднее время между инцидентами	~77 минут	Нормальный интервал в рабочее время

Baseline по типам событий

Категория событий	**Нормальный диапазон**	**Аномалия (превышение)**
Аутентификация (Logon/Logoff)	15-25 событий/день	>50 событий/день
Изменения файлов (FIM/syscheck)	5-10 событий/день	>30 событий/день

Системные события (systemd/service)	20-40 событий/день	>100 событий/день
Сетевые аномалии (promiscuous mode)	0-2 события/день	>10 событий/день
Brute-force атаки	0-5 событий/день	>20 событий/день

Распределение по уровням критичности (нормальный baseline)

Уровень (Level)	**Нормальное количество**	**Процент от общего**	**Описание**
0-3 (Info/Low)	~4 500	65.8%	Рутинные события: логины, logoff, информационные
4-6 (Medium)	~1 800	26.3%	Предупреждения: изменения конфигов, установка ПО
7-9 (High)	~470	6.9%	Важные события: sudo, изменения критичных файлов
10-15 (Critical)	~72	1.0%	Критичные: promiscuous mode, brute-force, dpkg errors

Выявленные отклонения от baseline

1. Аномалия: Systemd service failures (Rule 40703)

- Наблюдение: 1 325 событий за год (3.6 события/день)
- Baseline: Норма 0.5-1 событие/день
- Отклонение: Превышение в 3-7 раз
- Вывод: Нестабильная работа системных служб на нескольких хостах. Требуется аудит состояния сервисов и обновление пакетов.

2. Аномалия: Dpkg half configured (Rule 2904)

- Наблюдение: 437 событий за год
- Baseline: Норма 0-5 событий/день
- Отклонение: Систематические проблемы с установкой пакетов
- Вывод: Необходимо завершить прерванные установки (dpkg --configure -a) и проверить целостность пакетной базы.

3. Аномалия: Interface in promiscuous mode (Rule 5104)

- Наблюдение: 428 событий за год
- Baseline: Норма 0-2 события/день
- Отклонание: Превышение в 200+ раз
- Вывод: Регулярное включение сниффинга на сетевых интерфейсах. Может быть легитимным (сканирование OpenVAS) или признаком reconnaissance-активности.

Рекомендации по оптимизации SIEM

Для снижения EPS и шума:

1. Фильтрация рутинных событий:
    - Исключить из алертинга события уровня 0-3 (они остаются в логах для forensics)
    - Агрегировать повторяющиеся события (например, 10 одинаковых login events → 1 событие с count=10)
2. Тонкая настройка правил:
    - Добавить whitelist для легитимных promiscuous mode events (IP OpenVAS: 10.0.20.65)
    - Исключить CRON-логины из правил аутентификации
3. Оптимизация хранения:
    - Hot storage (30 дней): все события level ≥ 4
    - Warm storage (90 дней): все события level ≥ 7
    - Cold storage (1 год): только критичные инциденты (level ≥ 10)

Ожидаемый результат: Снижение EPS на 40-60%, уменьшение alert fatigue у аналитиков на 70%.

КРИТИЧЕСКИЕ СОБЫТИЯ

1. Атаки Brute-Force (Rule 200010)

Количество событий: 48
Уровень критичности: 5
Цель: Windows системы
MITRE ATT&CK: T1110 - Brute Force
Анализ:

- Зафиксированы множественные неудачные попытки входа
- Источники атак: 10.0.30.12 (Kali Linux)
- Целевые учетные записи: student, admin

Рекомендации:

- Включить Account Lockout Policy (5 попыток)
- Настроить Fail2ban на критических системах
- Внедрить MFA для всех удаленных подключений

2. Сетевой интерфейс в promiscuous mode (Rule 5104)

Количество событий: 428
Уровень критичности: 8
Риск: Перехват сетевого трафика
Рекомендации:

- Проверить легитимность использования promiscuous mode
- Ограничить права на включение режима
- Мониторить сетевую активность

3. Неудачные попытки входа (Rule 60122)

Количество событий: 41
Уровень критичности: 5
MITRE ATT&CK: T1110.001 - Password Guessing
Анализ:

- Event ID 4625 (Windows Security Log)
- Причины: Unknown user or bad password
- Требуется корреляция с другими событиями

СОБЫТИЯ CIS BENCHMARK

Зафиксировано множество нарушений CIS Benchmark для Ubuntu 20.04 LTS:

Критические нарушения (Level 7):

- 19007: Default deny firewall policy
- 19007: Disable USB Storage
- 19007: Ensure IPv6 loopback traffic is configured
- 19007: Ensure SSH LoginGraceTime is configured
- 19007: Ensure auditd service is enabled

Нарушения Level 9 (критические):

- 19014: Ensure changes to system administration scope (sudoers) is collected
- 19014: Ensure discretionary access control permission modification events are collected
- 19014: Ensure events that modify the system's network environment are collected

---

КРИТИЧЕСКИЕ РИСКИ И РЕКОМЕНДАЦИИ

НЕМЕДЛЕННЫЕ ДЕЙСТВИЯ (24-48 часов)

1. Устранение RCE уязвимости Drupal

Приоритет: КРИТИЧЕСКИЙ
Срок: 24 часа
Действия:

```
# Обновить Drupal core и модули
drush up drupal
drush up coder

# Проверить наличие webshell'ов
find /var/www -name "*.php" -mtime -7 -exec grep -l "eval\|base64_decode" {} \;

# Проверить логи на предмет эксплуатации
grep "coder_upgrade.run.php" /var/log/apache2/access.log
```

2. Блокировка опасных HTTP методов

Приоритет: КРИТИЧЕСКИЙ

Срок: 24 часа
Apache:

```
<LimitExcept GET POST HEAD>
   Require all denied
</LimitExcept>
```

Nginx:

```
if ($request_method !~ ^(GET|HEAD|POST)$ ) {
   return 444;
}
```

3. Обновление Drupal от SQLi

Приоритет: КРИТИЧЕСКИЙ
Срок: 24 часа
Действия:

- Обновить до Drupal 7.32+ или Drupal 10.x
- Проверить базу на наличие SQL-инъекций:

```
SELECT * FROM users WHERE uid = 1;
SELECT * FROM variable WHERE name LIKE '%filter%';
```

СРОЧНЫЕ ДЕЙСТВИЯ (1 неделя)

4. Hardening SSL/TLS

Приоритет: ВЫСОКИЙ
Срок: 7 дней
Конфигурация Apache:

```
SSLProtocol all -SSLv3 -TLSv1 -TLSv1.1
SSLCipherSuite ECDHE-ECDSA-AES128-GCM-SHA256:ECDHE-RSA-AES128-GCM-SHA256
SSLHonorCipherOrder off
```

5. Настройка Account Lockout Policy

Приоритет: ВЫСОКИЙ
Срок: 7 дней

Group Policy:

Account Lockout Threshold: 5 попыток
Account Lockout Duration: 30 минут
Reset Account Lockout Counter: 30 минут

6. Внедрение LAPS

Приоритет: ВЫСОКИЙ
Срок: 7 дней
Действия:

```
# Установить LAPS
Import-Module AdmPwd.PS

# Обновить схему AD
Update-AdmPwdADSchema

# Предоставить права
Set-AdmPwdReadPasswordPermission -OrgUnits "OU=Computers,DC=acme,DC=skb"

# Настроить GPO
# Computer Configuration → Policies → Administrative Templates → LAPS
```

СРЕДНЕСРОЧНЫЕ ДЕЙСТВИЯ (1 месяц)

7. Обновление jQuery

Приоритет: СРЕДНИЙ
Срок: 30 дней
Действия:

- Обновить jQuery до версии 3.6.0+
- Протестировать совместимость
- Обновить phpMyAdmin до последней версии

8. Hardening SSH

Приоритет: СРЕДНИЙ
Срок: 30 дней
/etc/ssh/sshd_config:

Protocol 2
HostKey /etc/ssh/ssh_host_ed25519_key
HostKey /etc/ssh/ssh_host_rsa_key
Ciphers chacha20-poly1305@openssh.com,aes256-gcm@openssh.com
MACs hmac-sha2-512-etm@openssh.com,hmac-sha2-256-etm@openssh.com
KexAlgorithms curve25519-sha256@libssh.org,diffie-hellman-group-exchange-sha256

9. Настройка резервного копирования AD

Приоритет: ВЫСОКИЙ
Срок: 7 дней
План:

- Ежедневный инкрементальный бэкап
- Еженедельный полный бэкап
- Хранение: 30 дней локально, 90 дней в облаке
- Тестирование восстановления: ежемесячно

10. Внедрение Protected Users

Приоритет: СРЕДНИЙ
Срок: 30 дней
PowerShell:

```
# Добавить пользователей в Protected Users
Add-ADGroupMember -Identity "Protected Users" -Members "admin1","admin2"

# Проверить членство
Get-ADGroupMember "Protected Users"
```

ДОЛГОСРОЧНЫЕ УЛУЧШЕНИЯ (3 месяца)

11. Внедрение MFA

Приоритет: СРЕДНИЙ
Срок: 90 дней
Решения:

- Azure AD Multi-Factor Authentication
- Duo Security
- Okta Verify

12. Расширенный аудит и мониторинг

Приоритет: СРЕДНИЙ

Срок: 90 дней
Настройка Advanced Audit Policy:

Account Logon: Success, Failure
Account Management: Success, Failure
Directory Service Access: Success, Failure
Logon/Logoff: Success, Failure
Privilege Use: Success, Failure

13. Сегментация сети

Приоритет: СРЕДНИЙ
Срок: 90 дней
Действия:

- Отделить DMZ от внутренней сети
- Настроить VLAN для различных сервисов
- Внедрить микросегментацию

ДОПОЛНИТЕЛЬНЫЕ РЕКОМЕНДАЦИИ

Обновление программного обеспечения

Система	Текущая версия	Рекомендуемая	Приоритет
Drupal	7.5	10.x	Критический
jQuery	1.6.2	3.6.0+	Высокий
phpMyAdmin	3.5.8	5.3.x	Высокий
OpenSSH	6.6.1p1	9.x	Средний
Apache	2.4.7	2.4.54+	Средний

Мониторинг и реагирование

Настроить алерты в Wazuh:

1. Множественные неудачные логины (>5 за 5 минут)
2. Вход в систему в нерабочее время
3. Добавление в привилегированные группы
4. Изменения в GPO
5. Отключение аудита

Playbook реагирования:

1. Детектирование → SIEM алерт
2. Анализ → Корреляция событий
3. Классификация → Определение уровня инцидента
4. Реагирование → Блокировка IP, сброс паролей
5. Восстановление → Устранение уязвимости
6. Уроки → Обновление правил детектирования

ЗАКЛЮЧЕНИЕ

Инфраструктура acme.skb находится в критическом состоянии с точки зрения безопасности. Обнаруженные уязвимости позволяют злоумышленнику:

1. Выполнять произвольный код на веб-сервере (CVSS 10.0)
2. Получать доступ к базе данных через SQL-инъекцию
3. Перехватывать учетные данные через слабые протоколы
4. Проводить атаки Pass-the-Hash из-за отсутствия LAPS
5. Компрометировать домен через устаревшие протоколы

Необходимые действия:

1. Немедленно (24 часа):
    - Обновить Drupal и закрыть RCE
    - Отключить опасные HTTP методы
    - Заблокировать источники атак brute-force
2. В течение недели:
    - Настроить Account Lockout Policy

    - Внедрить LAPS
    - Обновить SSL/TLS конфигурацию
    - Настроить резервное копирование AD
3. В течение месяца:
    - Обновить все устаревшие компоненты
    - Внедрить Protected Users
    - Настроить расширенный аудит
4. В течение квартала:
    - Внедрить MFA
    - Провести сегментацию сети
    - Разработать и протестировать DRP

Прогноз: При отсутствии мер в течение 30 дней вероятность успешной компрометации инфраструктуры составляет >90%.

ПРИЛОЖЕНИЯ

Приложение А: Список CVE

CVE	CVSS	Описание	Статус
CVE-2014-3704	7.5	Drupal Core SQLi	Не исправлено
CVE-2016-2183	7.5	SWEET32	Не исправлено
CVE-2012-6708	6.1	jQuery XSS	Не исправлено
CVE-2011-4969	4.3	jQuery XSS	Не исправлено
CVE-2011-3389	4.3	BEAST	Не исправлено
CVE-2015-0204	4.3	FREAK	Не исправлено

Приложение B: Ссылки на ресурсы

1. Drupal Security Advisories: https://www.drupal.org/security
2. OWASP Top 10: https://owasp.org/www-project-top-ten/
3. CIS Benchmarks: https://www.cisecurity.org/cis-benchmarks
4. MITRE ATT&CK: https://attack.mitre.org/
5. Wazuh Documentation: https://documentation.wazuh.com/

Приложение C: Контакты для эскалации

- CISO: security@acme.skb
- SOC: soc@acme.skb
- Emergency: +7 (XXX) XXX-XX-XX